

Relatório Técnico - Projeto: Conexões Seguras

Ana Livia dos Santos Lopes, Jacquys barbosa da Silva, Jhônatas Lopes da Silva, Luis Gustavo Cesar Consoli de Almeida

Módulo 1: Sniffing e Intercepção (Camada 2 e 3)

O Controlador de Interface de Rede (NIC) realiza a ponte entre o meio físico de transmissão e as camadas lógicas do sistema operacional. Operando na Camada de Enlace (Camada 2 do

Modelo OSI), a NIC executa por padrão uma filtragem de hardware restritiva. No modo normal (não-promíscuo), a placa rejeita frames elétricos que endereços MAC de destino não são o mesmo ao seu próprio MAC físico, ao endereço de Broadcast (ff:ff:ff:ff:ff:ff) ou aos grupos de Multicast inscritos. Esse descarte impede interrupções de hardware desnecessárias na CPU e economizando memória RAM.

O Modo Promíscuo é uma configuração de baixo nível que inverte essa lógica operacional. Quando ativado por ferramentas como o Wireshark, o sistema operacional altera os registradores internos do chip da NIC através do driver. Essa instrução desativa o circuito de validação de endereços de destino. Como resultado, o filtro de hardware é desativado, a interface passa a coletar todos os frames presentes no meio físico e os armazena temporariamente em seus buffers, transferindo os dados diretamente para a memória do sistema e para a camada de aplicação

Contudo, a capacidade prática de interceptar tráfego de terceiros neste modo depende da topologia da Camada 2. Em redes antigas estruturadas com Hubs, o modo promíscuo é totalmente eficaz de forma nativa, pois o Hub replica os sinais elétricos de uma porta para todas as outras. Já nas redes modernas baseadas em Switches, o cenário muda. O Switch utiliza a Tabela CAM para comutar pacotes Unicast ponto a ponto, enviando o frame estritamente para a porta física do destinatário real.

Assim, pensando em como o modo promíscuo altera o comportamento, o modo promíscuo precisa que os pacotes cheguem fisicamente à placa de rede para funcionar. Como o Switch bloqueia essa chegada, a sua alteração de hardware não funciona, para o modo promíscuo realmente conseguir capturar algo em redes modernas, ele depende de técnicas como SPAN ou ARP Spoofing para forçar os pacotes a entrarem na placa.

Módulo 2: Criptografia e Handshake (A base do TLS)

1. Criptografia Híbrida: Por que o HTTPS não utiliza apenas criptografia assimétrica (RSA/ECC) para todo o tráfego? Explique o conceito de usar criptografia assimétrica para a troca de chaves e simétrica (AES) para a transferência de dados .

O protocolo HTTPS baseia-se num modelo de criptografia híbrida para garantir uma comunicação segura e eficiente na Internet, combinando os pontos fortes da criptografia assimétrica e da criptografia simétrica. Possuir esses dois tipos de abordagem é necessária, embora a criptografia assimétrica seja extremamente robusta para iniciar uma comunicação de forma segura sem a existência de um segredo pré-partilhado, ela exige um esforço computacional muito elevado. Sendo assim, torna a transferência de pacotes pesada e lenta para processar, quando os grandes volumes de dados que circulam numa navegação web normal. Então, a solução encontrada pelos protocolos de segurança (como o TLS/SSL) foi unir a segurança infalível da troca inicial de chaves do método assimétrico com a velocidade e eficiência de processamento do método simétrico.

Na fase inicial do estabelecimento da conexão no processo do Three Handshake, é utilizada a criptografia assimétrica, utilizando algoritmos conceituados como o RSA ou o ECC. Neste momento crucial, o cliente conecta-se ao servidor e recebe o seu certificado digital, que contém a chave pública do mesmo. O cliente gera então uma chave de sessão aleatória e utiliza essa chave pública para a encriptar, enviando-a de volta para o servidor. Dessa forma, uma vez encriptada com a chave pública, essa mensagem só pode ser descriptada pela chave privada correspondente, que se encontra guardada com segurança no servidor. Isto garante que, mesmo que um atacante intercepte a comunicação, não conseguirá descobrir a chave de sessão, resolvendo assim o problema da partilha segura de chaves num ambiente público e não confiável.

Assim que o servidor recebe a mensagem e utiliza a sua chave privada para revelar a chave de sessão, concluindo a fase assimétrica. A partir desse exato momento, tanto o cliente quanto o servidor possuem agora o mesmo segredo partilhado, a comunicação transita exclusivamente para o uso da criptografia simétrica, recorrendo a algoritmos de alto desempenho como o AES. Toda a transferência de dados real — desde as palavras-passe introduzidas pelo utilizador até ao carregamento de imagens, páginas e transferência de ficheiros — passa a ser cifrada e decifrada utilizando esta única chave de sessão. A grande vantagem da criptografia simétrica é a sua simplicidade matemática comparativa, resultando numa enorme rapidez de processamento. Esta transição é o que torna viável a manutenção

de um tráfego de dados constante, contínuo e seguro, sem causar atrasos na navegação ou sobrecarregar os recursos dos dispositivos envolvidos.

Módulo 3: Segurança na Camada de Aplicação (Desenvolvimento)

1. Gestão de Sessão e Cookies: O que são Cookie SessionID e quais preocupações devo ter com eles, na posição de pessoa desenvolvedora de software?

O SessionID é um identificador único em formato de string criptografado, gerado pelo servidor depois de uma autenticação bem sucedida de um usuário. Como o protocolo HTTP é stateless o SessionID é anexado no cabeçalho de cada requisição HTTP, isso permite que o servidor reconheça o usuário sem exigir uma nova autenticação.

Como desenvolvedor é importante garantir a segurança desse serviço por meios de boas práticas, como não permitir que o cookie seja acessado pelo lado do cliente evitando ataques XSS (Cross-Site Scripting), proteger o cookie em cada requisição para evitar ataques CSRF (Cross-Site Request Forgery), gerar novos identificadores a cada novo login, configurar um ciclo de vida para as sessões, tudo isso vai permitir que a sua aplicação tenha mais segurança.

2. Qual o papel do HTTPS na proteção de cookies de sessão durante a transmissão na rede? O que acontece se a aplicação usar apenas HTTP?

Diferente do HTTP o HTTPS utiliza a camada TLS/SSL para criptografar o canal de comunicação entre o cliente e o servidor antes que qualquer dado seja transmitido. O papel do HTTPS é proteger os cookies enquanto eles estiverem em trânsito, quando a conexão é estabelecida via TLS todo o conteúdo da requisição é criptografado. Já o protocolo HTTP envia dados na rede em texto claro, assim expondo os dados a ataques via interceptação de tráfego, como Sniffing ou Man-in-the-Middle, esses métodos garantem ao atacante acesso ao SessionID do usuário e outros dados sensíveis que podem ser usados ou alterados.